IS06 — Third-Party Supplier Security Policy

[Company] IIoT Platform

Project name: [Company] Security Policies	Status: Active
Date: [Date]	Version: 1.0
Author: [Author Name]	Reviewer: [Reviewer Name]

Versions

Revision	Date	Author	Description
1.0	[Date]	[Author Name]	Initial release

Related Standards, Policies and Processes

IS01 - [Company] Information Security Policy

Definitions and Terms

Definitions and terms used in this policy follow the SANS Institute Glossary of Security Terms.

Overview

This policy defines the security requirements for engaging with third-party suppliers and integrating their products (hardware, software, or firmware) into the [Company] IIoT Platform. It establishes a framework for assessing, monitoring, and mitigating risks associated with the supply chain. As [Company] is part of [Division] within [Parent Company], this policy operates in alignment with parent company directives, ensuring a unified security posture.

Purpose

The purpose of this policy is to:

Minimize Supply Chain Risk: Prevent the introduction of vulnerabilities through external software, hardware, or services.

Ensure Product Integrity: Validate that all third-party components (including IoT firmware and system updates) meet [Company] security standards before reaching the customer.

Enforce Accountability: Establish clear contractual obligations regarding security proofs, vulnerability management, and remediation SLAs.

Scope

Internal Applicability: All employees, contractors, consultants, temporary and other workers of [Company] working on the [Company] IIoT Platform must adhere to this policy when selecting, onboarding, or managing external vendors.

External Applicability: This policy applies to all third-party suppliers, vendors and partners providing hardware, software, firmware, cloud services, or consulting to the [Company] platform. The requirements defined herein must be reflected in the binding agreements (contracts/SLAs) with these entities.

Policy

Governance and Precedence

Parent Company Alignment: [Company] operates under the governance of [Parent Company] and [Division]. Policies and procedures established by these parent entities take precedence. This policy addresses operational risks specific to the [Company] platform that are not covered by general corporate policies, or that require stricter controls than they provide.

Security Team Authority: The [Company] Security Team maintains the authority to veto any supplier or third-party component that fails to meet risk acceptance criteria, regardless of business utility.

Supplier Assessment and Onboarding

Prior to signing a contract or integrating a product, the Security Team must evaluate the supplier's security posture.

Proof of Security: Suppliers are required to provide verifiable proof of their security state. This includes, but is not limited to:

Recent independent penetration testing reports.

Information Security Policies and DevSecOps standards.

Compliance certifications (e.g., ISO 27001, SOC 2) where applicable.

Risk Evaluation: The Security Team will assess the risk associated with the supplier based on the data they will access and the critical function of their component.

Component Validation (Internal Testing)

To ensure the integrity of the [Company] platform, a "Zero Trust" approach is applied to incoming third-party deliverables.

Pre-Release Evaluation: Every new digital or hardware component, including new firmware versions, IoT system updates, or libraries, must undergo internal security evaluation before being released to production or delivered to customers.

Penetration Testing: Internal penetration testing activities must be performed on major releases of third-party components (e.g., a new IoT sensor firmware) to identify vulnerabilities that may have been missed by the vendor.

Vulnerability Management and SLAs

Communication Channels: Suppliers must provide a clear, dedicated information channel for security notifications, vulnerability disclosures, and an escalation path for critical incidents.

Remediation SLAs: Service Level Agreements (SLAs) for security remediation must be defined and agreed upon at the contract level. Recommended baselines are:

Critical Vulnerabilities: Patch/Mitigation provided within 24-48 hours.

High Vulnerabilities: Patch provided within 7-14 days.

Policy Compliance

Compliance Measurement

The Security Team will measure compliance through:

Supplier Audit Reviews: Verification that all active suppliers have up-to-date security proofs on file.

Release Gate Checks: Confirmation that no third-party component (firmware/software) was released without a sign-off from the internal security testing process.

SLA Monitoring: Tracking vendor response times against contractual security SLAs during incidents.

Exceptions

Any exception to the policy must be approved by the Security Team in advance. Exceptions regarding parent company policies must be escalated to [Parent Company]/[Division] compliance officers.

Non-Compliance

An employee found to have violated this policy may be subject to disciplinary action. Suppliers found in violation may be subject to contract termination or legal action.